Informe de seguridad: Server-Side Template Injection (SSTI)

1. Título

Server-Side Template Injection (SSTI) con ejecución de comandos del sistema

2. Descripción

Se identificó una vulnerabilidad de tipo *Server-Side Template Injection* (SSTI) en el parámetro `message` de la aplicación web.

La vulnerabilidad se produce cuando una aplicación procesa datos controlados por el usuario como parte de una plantilla del lado del servidor, en lugar de tratarlos exclusivamente como datos.

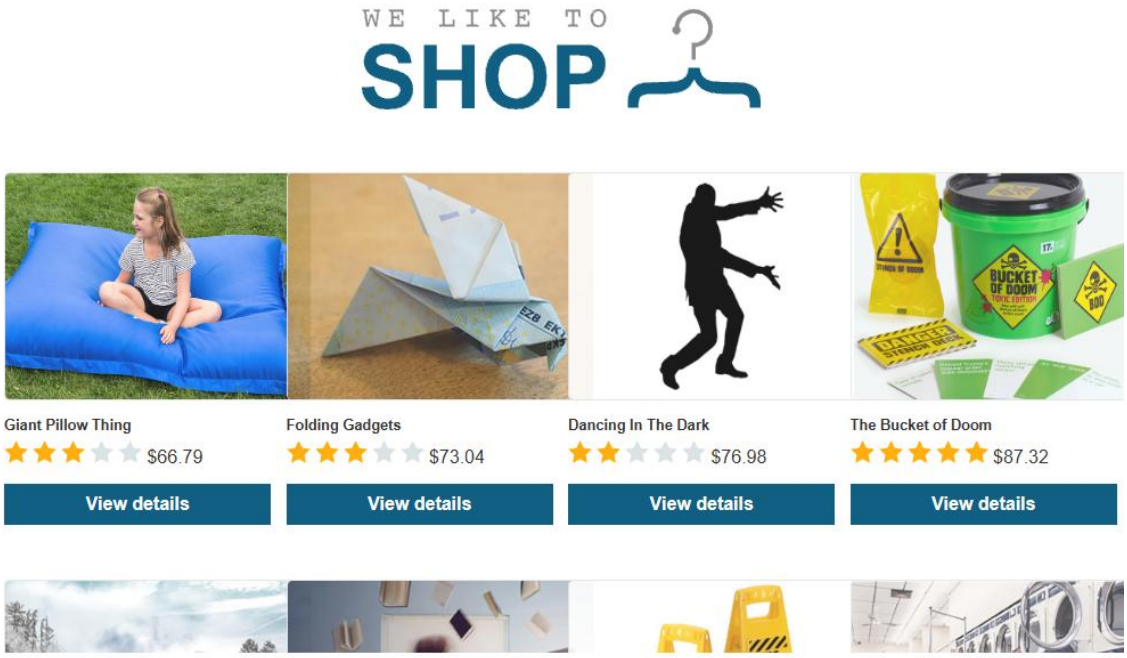
Durante las pruebas, se introdujo una expresión matemática que devolvió el resultado `49`, demostrando que la entrada era evaluada por el motor de plantillas. Posteriormente, se utilizó la vulnerabilidad para ejecutar un comando del sistema operativo, lo que permitió completar el laboratorio de PortSwigger Web Security Academy.

Este comportamiento demuestra que la vulnerabilidad puede superar la evaluación de expresiones y llegar a la ejecución de comandos, con un impacto potencialmente crítico.

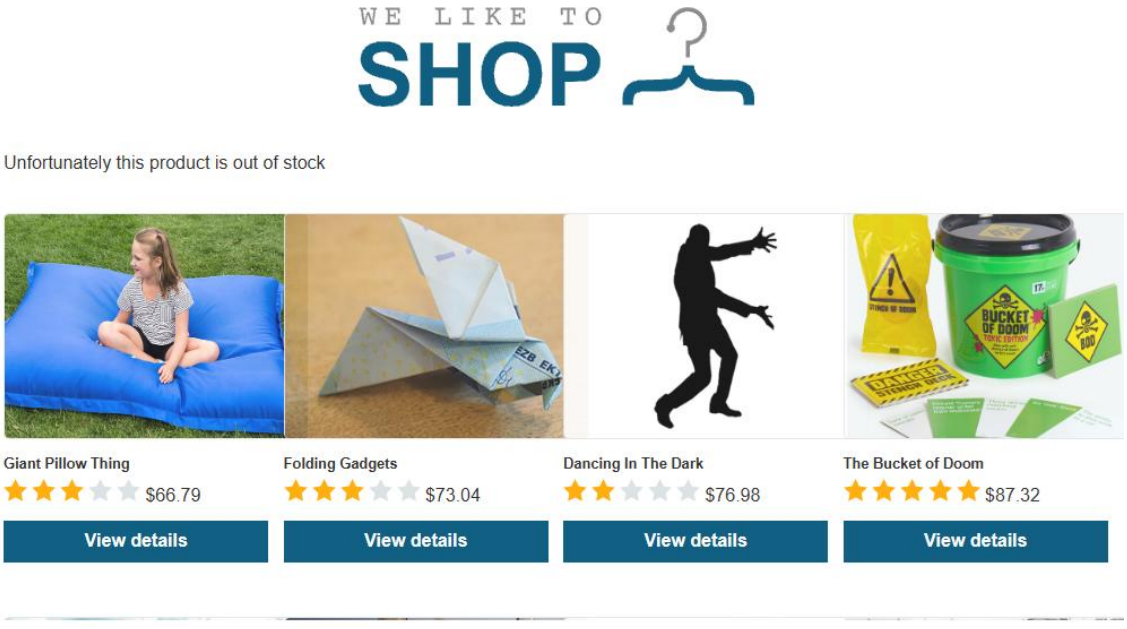
3. Evidencia

Las siguientes capturas documentan el proceso de identificación y explotación de la vulnerabilidad.

1. Página inicial de la aplicación utilizada durante las pruebas.

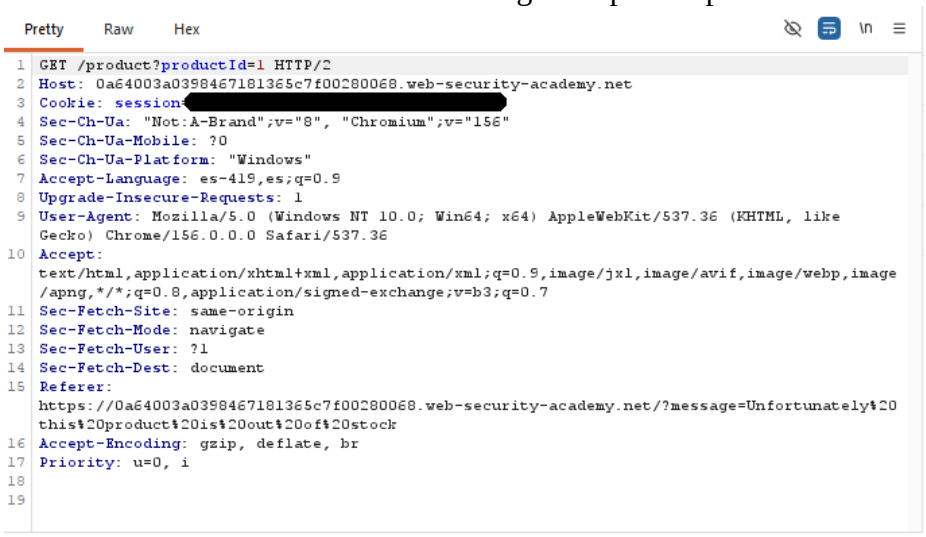


2. Página del producto utilizada para explorar el funcionamiento de la aplicación.



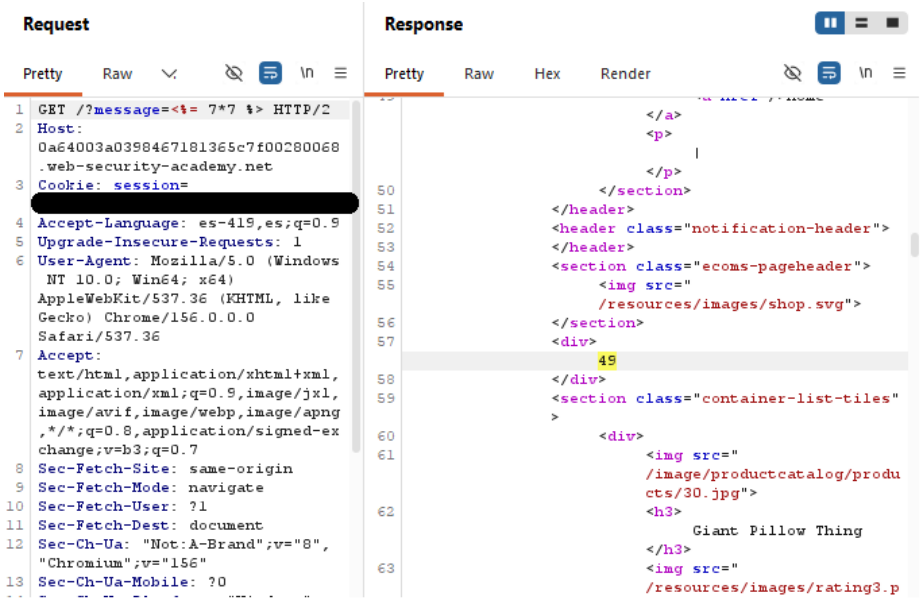
3.

Solicitud HTTP relacionada con la navegación por la aplicación.



```
Pretty  Raw  Hex
GET /product?productId=1 HTTP/2
Host: 0a64003a0398467181365c7f00280068.web-security-academy.net
Cookie: session=[redacted]
Sec-Ch-Ua: "Not:A-Brand";v="8", "Chromium";v="156"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Windows"
Accept-Language: es-419,es;q=0.9
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like
Gecko) Chrome/156.0.0.0 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/jxl,image/avif,image/webp,image
/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Referer:
https://0a64003a0398467181365c7f00280068.web-security-academy.net/?message=Unfortunately%20
this%20product%20is%20out%20of%20stock
Accept-Encoding: gzip, deflate, br
Priority: u=0, i
```

4. Solicitud y respuesta que muestran la evaluación de una expresión matemática mediante el parámetro `message`, obteniendo el resultado `49`.



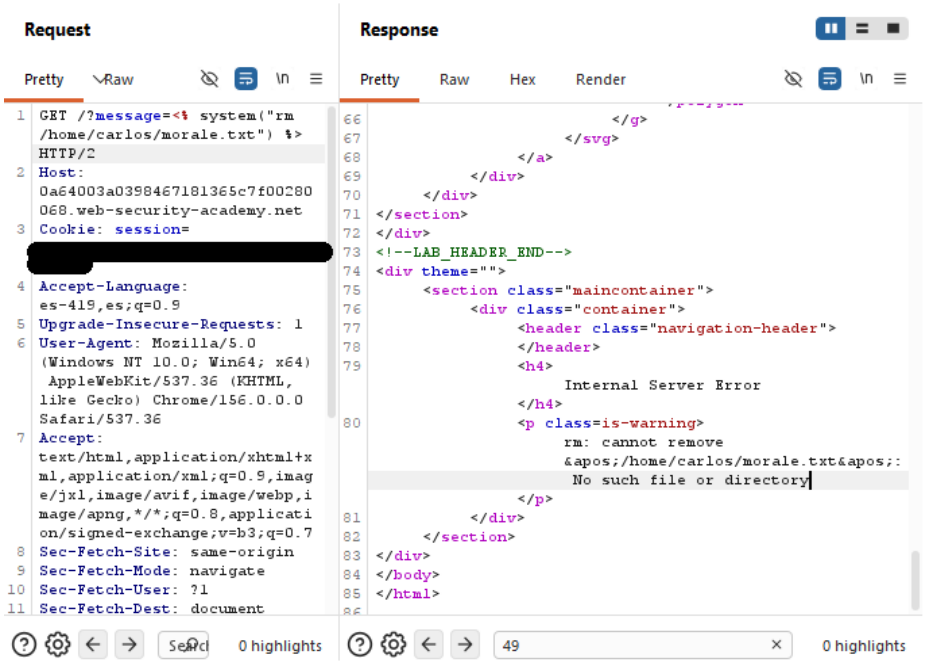
Request

```
Pretty  Raw
GET /?message=<%= 7*7 %> HTTP/2
Host:
0a64003a0398467181365c7f00280068
.web-security-academy.net
Cookie: session=
[redacted]
Accept-Language: es-419,es;q=0.9
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows
 NT 10.0; Win64; x64)
AppleWebKit/537.36 (KHTML, like
Gecko) Chrome/156.0.0.0
Safari/537.36
Accept:
text/html,application/xhtml+xml,
application/xml;q=0.9,image/jxl,
image/avif,image/webp,image/apng
,*/*;q=0.8,application/signed-ex
change;v=b3;q=0.7
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Sec-Ch-Ua: "Not:A-Brand";v="8",
"Chromium";v="156"
Sec-Ch-Ua-Mobile: ?0
```

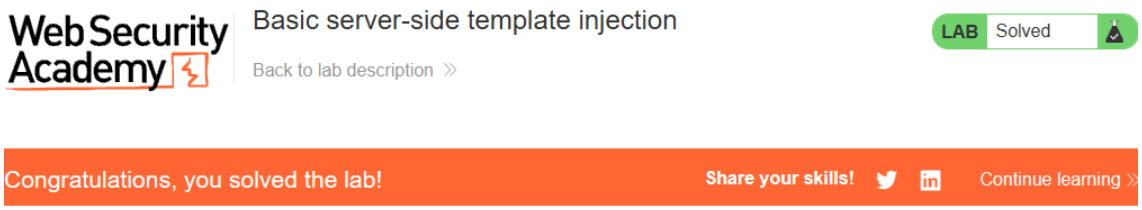
Response

```
Pretty  Raw  Hex  Render
                    </a>
                    <p>
                        |
                    </p>
                </section>
            </header>
            <header class="notification-header">
            </header>
            <section class="ecoms-pageheader">
                <img src="
                /resources/images/shop.svg">
            </section>
            <div>
                49
            </div>
            <section class="container-list-tiles"
            >
                <div>
                    <img src="
                    /image/productcatalog/produ
                    cts/30.jpg">
                    <h3>
                        Giant Pillow Thing
                    </h3>
                    <img src="
                    /resources/images/rating3.p
```

5. Evidencia de la prueba de ejecución de comandos del sistema mediante la vulnerabilidad. El resultado debe interpretarse según lo que muestre la captura, sin asumir que un mensaje de error demuestra por sí solo la eliminación del archivo.



6. Captura final que confirma que el laboratorio de PortSwigger fue resuelto.



4. Impacto

La explotación de una vulnerabilidad SSTI puede comprometer la confidencialidad, integridad y disponibilidad de una aplicación, dependiendo de los permisos del proceso y de las capacidades del motor de plantillas.

- **Confidencialidad (C):** un atacante podría acceder a información sensible disponible para el proceso del servidor.
- **Integridad (I):** podría modificar archivos o alterar recursos accesibles con los permisos del proceso.
- **Disponibilidad (A):** podría ejecutar acciones que afecten el funcionamiento de la aplicación o del sistema.

En este laboratorio se demostró la evaluación de expresiones y se avanzó hasta la ejecución de comandos del sistema. El alcance real del impacto en un entorno de producción dependería de los permisos disponibles y de las restricciones del entorno de ejecución.

5. Causa raíz

La causa raíz es el procesamiento de entrada controlada por el usuario como contenido ejecutable de una plantilla del lado del servidor.

Esta implementación permite que una entrada diseñada por un atacante sea interpretada por el motor de plantillas, en lugar de procesarse únicamente como texto.

6. Remediación

Se recomienda implementar las siguientes medidas:

1. **Separar los datos de la lógica de las plantillas:** evitar que las entradas del usuario se interpreten como código de plantilla.
2. **Utilizar mecanismos seguros de renderizado:** pasar los valores del usuario como datos y no construir plantillas dinámicamente a partir de entradas no confiables.
3. **Restringir las capacidades del motor de plantillas:** deshabilitar funcionalidades peligrosas cuando no sean necesarias.
4. **Aplicar el principio de mínimo privilegio:** ejecutar la aplicación con los permisos estrictamente necesarios.
5. **Restringir la ejecución de comandos del sistema:** evitar invocar comandos del sistema operativo desde el procesamiento de plantillas y, cuando sea necesario ejecutar procesos, utilizar mecanismos seguros que no interpreten la entrada como comandos.
6. **Agregar pruebas de seguridad:** comprobar que las entradas controladas por el usuario no puedan ejecutar expresiones arbitrarias dentro del motor de plantillas.

7. CVSS aproximado

Estimación provisional: CVSS 9.8 — Crítico.

Esta puntuación corresponde al escenario en el que la vulnerabilidad es explotable remotamente, sin autenticación ni interacción del usuario, y permite comprometer la confidencialidad, integridad y disponibilidad del sistema.

La puntuación debe confirmarse según las condiciones reales del laboratorio. Si existe autenticación obligatoria, el alcance de la explotación es más limitado o no se demuestra el impacto completo, el vector y la puntuación deben ajustarse.

8. Prioridad

Crítica, si se confirma la ejecución remota de comandos con impacto amplio y sin requisitos adicionales de acceso.

La vulnerabilidad debe corregirse prioritariamente porque una SSTI explotable puede permitir que un atacante ejecute acciones en el contexto del servidor.